

Arquitectura de Backend, Datos y Seguridad

La fundación que sostiene a **36 sedes**, **+25.000 personas** y el histórico completo de la organización. Diseño de base de datos, apertura a APIs, ciberseguridad, infraestructura y mecanismo de crecimiento modular — con su auditoría de conformidad.

Los cuatro requisitos de la Fase 1

La Fase 0 entregó la capa de aplicación. La Fase 1 construye la fundación que la sostiene. Estos son los cuatro requisitos que delimitan el alcance de este documento y el orden en que se resuelven.

REQUISITO 01

Arquitectura de datos
Modelo relacional normalizado y multi-sede, con linaje de origen y trazabilidad histórica, dimensionado para 25.000 personas y el histórico completo de la organización.

REQUISITO 02

Apertura a APIs
API pública versionada con contrato OpenAPI, credenciales independientes por consumidor y webhooks salientes, para integrar los sistemas actuales y futuros.

REQUISITO 03

Ciberseguridad
Seguridad aplicada por capas y verificable contra un estándar externo de referencia, con trazabilidad completa de accesos sobre datos sensibles.

REQUISITO 04

Fundación sostenible
Fundación de datos sustentada con dimensionamiento y costos, sin dependencia crítica de un único proveedor y con alternativa estándar para cada componente.

Criterio de redacción
Cada decisión técnica se presenta con su justificación y, donde existe una alternativa razonable, con el motivo por el que se descartó. El objetivo es que la mesa pueda evaluar cada opción con la misma información disponible.

Qué significa técnicamente esta escala

SEDES

36

3 países. Zonas horarias, monedas y tipos de documento distintos.

PERSONAS

25.000+

Adultos y menores. Los menores exigen protección reforzada por ley.

HISTÓRICO

10+ años

Datos que hoy viven en 99-o y deben migrar sin pérdida ni duplicado.

PICO REAL

~2.500

Usuarios concurrentes estimados el domingo 9-11 a.m. durante el registro.

Naturaleza del reto: no es un problema de volumen

- 25.000 registros es una tabla pequeña para PostgreSQL — un servidor modesto atiende eso sin despeinarse. **El reto real es otro**, y por eso el diseño se concentra ahí:
- **Aislamiento entre 36 sedes:** que el pastor de Panamá jamás pueda leer un registro de Barcelona, aunque el código tenga un error.
 - **Confidencialidad graduada:** diezmos, notas pastorales y consejería no son «datos»: son secretos con dueño y con ley.
 - **Trazabilidad:** poder responder «¿quién vio el diezmo de esta persona el 3 de marzo?» con una respuesta verificable.
 - **Linaje del histórico:** cada fila migrada debe saber de dónde vino y poder reconciliarse contra el origen.

Carga estimada en régimen

Peticiones API / día	180.000
Pico sostenido	120 req/s
Tamaño BD año 1	~18 GB
Tamaño BD año 5	~95 GB
Archivos (S3)	~250 GB
Eventos timeline/año	~4,2 M

Dimensionado con holgura x4 sobre lo observado en 99-o. La infraestructura propuesta absorbe este perfil con **menos del 25 % de utilización**.

Los 14 pilares de un backend sólido · 1 a 7

Antes de dibujar nada: esta es la lista de control contra la que se diseña y contra la que se audita al final del documento. Un backend que no cubre los 14 no es sólido, es una demo con suerte.

PILAR 01 · MODELO DE DATOS

Un solo registro maestro de persona

Normalización 3FN, claves foráneas reales, restricciones en la base (no solo en el código). Una persona = una fila, con identificadores múltiples y deduplicación activa. Sin esto, todo lo demás se contamina.

PILAR 03 · IDENTIDAD

Autenticación estándar y portátil

OIDC/OAuth 2.1, tokens de vida corta, MFA obligatorio para roles privilegiados, SSO hacia el Instituto (Moodle). La identidad no puede quedar secuestrada por un proveedor.

PILAR 05 · CIFRADO

En tránsito, en reposo y por columna

TLS 1.3 fuera; cifrado de disco y de respaldo dentro; y cifrado adicional de *columna* con llaves gestionadas para diezmos, notas pastorales y datos de menores.

PILAR 07 · CUMPLIMIENTO

Ley 1581, Habeas Data y menores

Autorización por canal, finalidad declarada, derecho de acceso/rectificación/supresión, tratamiento especial de menores (art. 7) y GDPR para la sede de Barcelona.

PILAR 02 · MULTI-TENANCY

Aislamiento demostrable por sede

Cada fila pertenece a una organización y a una sede. El aislamiento se aplica en el motor de base de datos, no en el **WHERE** que un programador puede olvidar.

PILAR 04 · AUTORIZACIÓN

Permisos por rol, alcance y sensibilidad

No basta «es pastor». Es *qué* rol, sobre *qué* sede/ministerio/grupo, sobre datos de *qué* nivel de sensibilidad. Decidido en un motor central, no repartido en 40 archivos.

PILAR 06 · AUDITORÍA

Registro de escritura y de lectura

Bitácora inmutable encadenada por hash. Casi nadie registra las *lecturas*; aquí es obligatorio para datos sensibles, porque la pregunta que va a llegar es «quién vio esto».

Cómo leer esta lista

Los 14 pilares vuelven a aparecer al final, en la **matriz de auditoría**, cada uno con su estado, su evidencia exigida y su compuerta de aprobación. Es el mismo documento el que se diseña y el que se verifica.

Los 14 pilares • 8 a 14

PILAR 08 • APIS

Contrato antes que código

OpenAPI 3.1 versionado, compatibilidad hacia atrás garantizada, límites de tasa, idempotencia en toda escritura, credenciales y cuotas por consumidor, webhooks firmados.

PILAR 10 • EVENTOS

Desacople por bandeja de salida transaccional

Los módulos no se llaman entre sí: publican hechos. Patrón *outbox* dentro de la misma transacción — o pasa todo, o no pasa nada. Cero eventos perdidos.

PILAR 12 • OBSERVABILIDAD

Saber que se rompió antes que el usuario

Trazas distribuidas, métricas, bitácoras estructuradas, alertas sobre objetivos de servicio declarados. Sin esto se opera a ciegas y se depura por anécdota.

PILAR 14 • MIGRACIÓN

Traer 99-o sin perder ni duplicar

Zona de aterrizaje, perfilado, mapeo, carga con linaje, reconciliación por conteos y sumas de verificación, período de doble operación y plan de reversión.

PILAR 09 • MODULARIDAD

Módulos que se anclan sin tocar el núcleo

Cada módulo declara su esquema, sus permisos, sus eventos y sus rutas en un manifiesto. Añadir un ministerio nuevo no debe requerir modificar el corazón del sistema.

PILAR 11 • OPERACIÓN

Todo como código, nada a mano

Infraestructura en Terraform, despliegue por tubería automática, tres ambientes idénticos, reversión en un clic. Ningún cambio en producción hecho desde una consola web.

PILAR 13 • CONTINUIDAD

Respaldos que se prueban restaurando

Regla 3-2-1, recuperación a un punto en el tiempo, y **simulacro trimestral de restauración**. Un respaldo que nunca se restauró no es un respaldo, es una esperanza.

Lo que deliberadamente NO está aquí

No hay microservicios, ni Kubernetes, ni un bus de mensajería empresarial. Para 36 sedes eso sería **costo y fragilidad sin beneficio**. La arquitectura elegida es sobria a propósito, y en la lámina siguiente se explica por qué.

Fundación de datos: evaluación de alternativas

La consideración sobre la robustez de Supabase para esta infraestructura es pertinente, y conviene precisar en qué punto aplica. Supabase **es** PostgreSQL, y PostgreSQL es el motor adecuado para este caso. La evaluación se centra, por tanto, en la plataforma que lo envuelve.

DIMENSIÓN	SUPABASE (EVALUADO)	FUNDACIÓN PROPUESTA AHORA	POR QUÉ IMPORTA AQUÍ
Motor de datos	PostgreSQL 15/16	PostgreSQL 16 — el mismo	● Nunca fue el problema. Se conserva.
Autorización	Solo RLS: la política vive en SQL, dispersa y difícil de probar	Motor de políticas en la aplicación <i>más</i> RLS como segunda barrera	Una política mal escrita expone 36 sedes. Se necesitan dos cerraduras independientes.
Identidad	Auth propietario del proveedor	Keycloak — OIDC estándar, propio, portátil	Migrar 25.000 identidades después es un proyecto en sí mismo. Se evita desde el día 1.
Red	Base expuesta a internet en los planes bajos	Base en subred privada, sin ruta pública	Elimina la superficie de ataque expuesta a internet.
Cifrado por columna	Sin gestión de llaves de primer nivel	Sobre-cifrado con llaves gestionadas (KMS) y rotación	Diezmos, notas pastorales y menores lo exigen.
Respaldo / PITR	Ventana atada al plan contratado	PITR a 35 días + copia en frío en otra cuenta	Un ataque con credenciales válidas también borra los respaldos si viven en el mismo sitio.
Salida del proveedor	Auth, Storage y Edge Functions son propietarios	Todo componente tiene reemplazo estándar	Sostenibilidad a 10 años para una organización que no puede rehacer esto cada 3.

Conclusión

Se conserva PostgreSQL. Se descarta la plataforma Supabase como fundación de producción. Supabase queda aprobado únicamente como entorno desechable de prototipado rápido, sin datos reales.

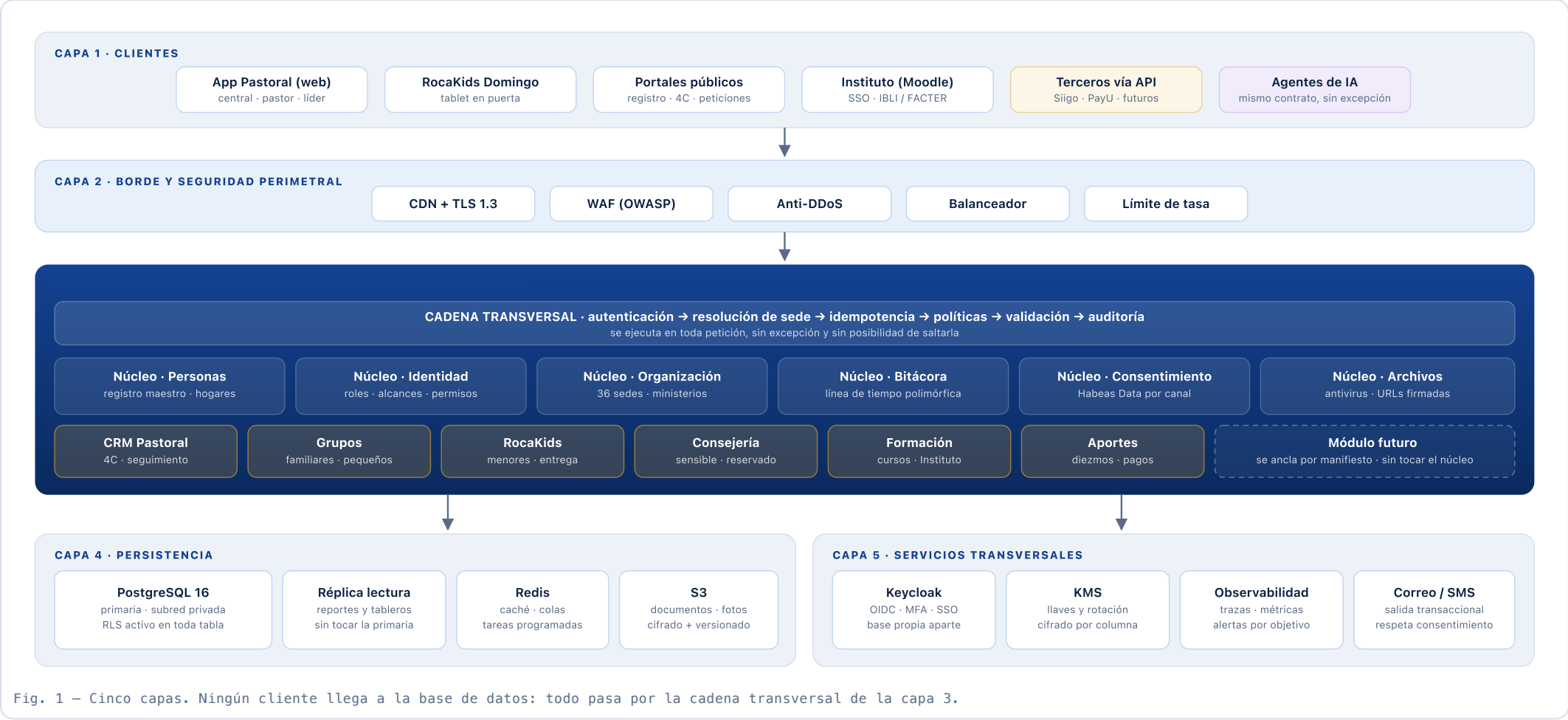
Lo que esto NO significa

No significa «más caro». El modelo financiero del Documento 2 demuestra que esta fundación cabe en el objetivo de referencia de **1.500.000 COP/mes**, porque el ahorro grande está en no pagar licencia por usuario.

El stack, con su justificación

CAPA	ELECCIÓN	POR QUÉ	ALTERNATIVA DESCARTADA
Base de datos	PostgreSQL 16 gestionado	Relacional maduro, restricciones fuertes, RLS nativo, JSONB para lo flexible, extensiones (pg_trgm , pgcrypto , pg_partman).	MySQL (RLS más pobre) · MongoDB (sin integridad referencial: inaceptable aquí)
Lenguaje	TypeScript · Node 22 LTS	Un solo lenguaje del navegador a la base. Tipado de extremo a extremo. Es además el lenguaje que mejor generan los asistentes de IA que ejecutarán la obra.	Java/Spring (más pesado para el equipo) · PHP/Laravel (es lo que ya se abandona)
Marco	NestJS — monolito modular	Sistema de módulos de primera clase, inyección de dependencias, capas explícitas. El módulo del marco es el módulo de negocio.	Microservicios: costo operativo x5 sin beneficio a esta escala
Acceso a datos	Drizzle ORM	Primero SQL y tipado. Toda consulta es inspeccionable y auditable; las migraciones son SQL plano que el CTO puede revisar línea a línea. Convive limpiamente con RLS.	Prisma: mejor experiencia, pero oculta el SQL y complica variables de sesión por conexión
Identidad	Keycloak (OIDC)	Estándar abierto, sin costo por usuario activo, federación con Google, MFA, y SSO listo hacia Moodle del Instituto.	Cognito/Auth0: cobran por usuario activo — inviable con 25.000 personas
Cola y caché	Redis + BullMQ	Trabajos diferidos, reintentos, tareas programadas, límites de tasa y sesiones.	SQS: correcto, pero ata más al proveedor
Archivos	S3 + URLs firmadas	Nada se sirve directo: enlace temporal, revisión antivirus al subir, cifrado en reposo.	Guardar en base de datos: infla respaldos y degrada
Ejecución	Contenedores en Fargate	Sin servidores que parchar, escalado por demanda, despliegue azul/verde.	Kubernetes: sobreingeniería · Servidor único: punto de fallo
Infra como código	Terraform	La infraestructura completa se recrea desde cero en menos de una hora. Toda modificación pasa por revisión.	Consola web: irreproducible, no auditable

Arquitectura general del sistema



Dónde se monta: topología de red

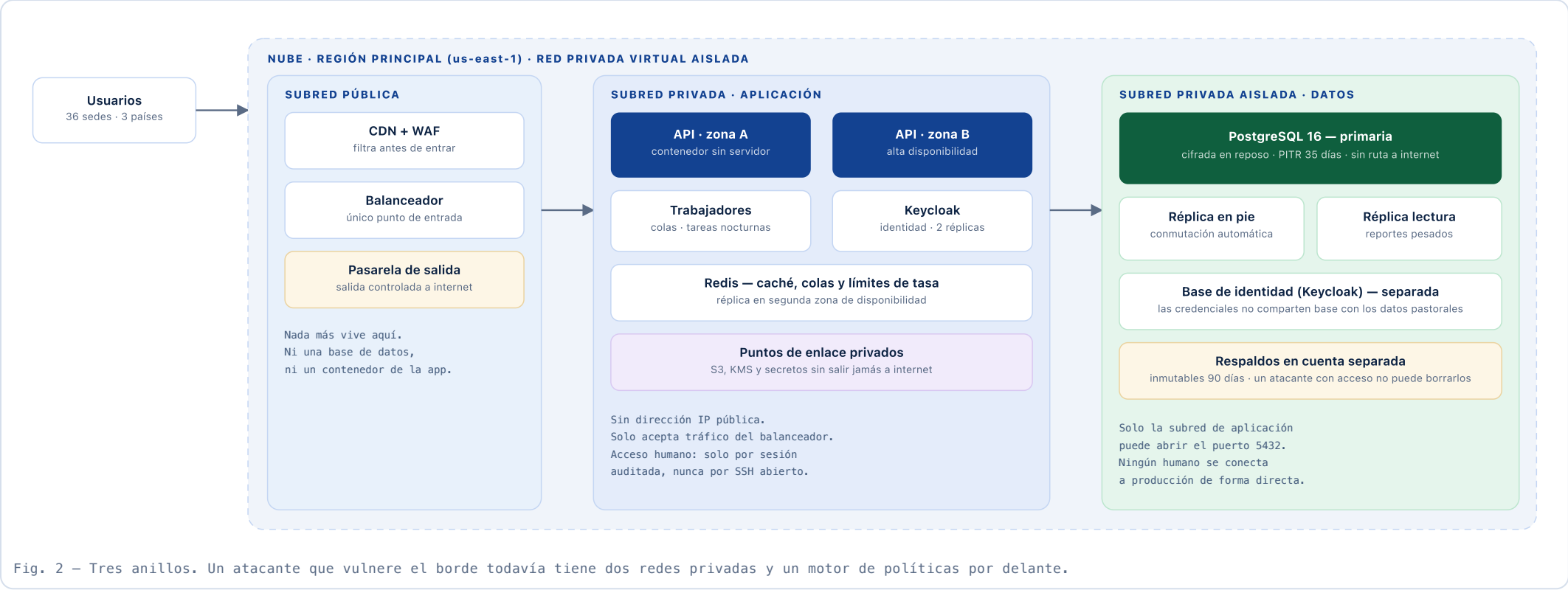


Fig. 2 – Tres anillos. Un atacante que vulnere el borde todavía tiene dos redes privadas y un motor de políticas por delante.

Aislamiento entre las 36 sedes

Modelo elegido: base compartida con aislamiento en el motor

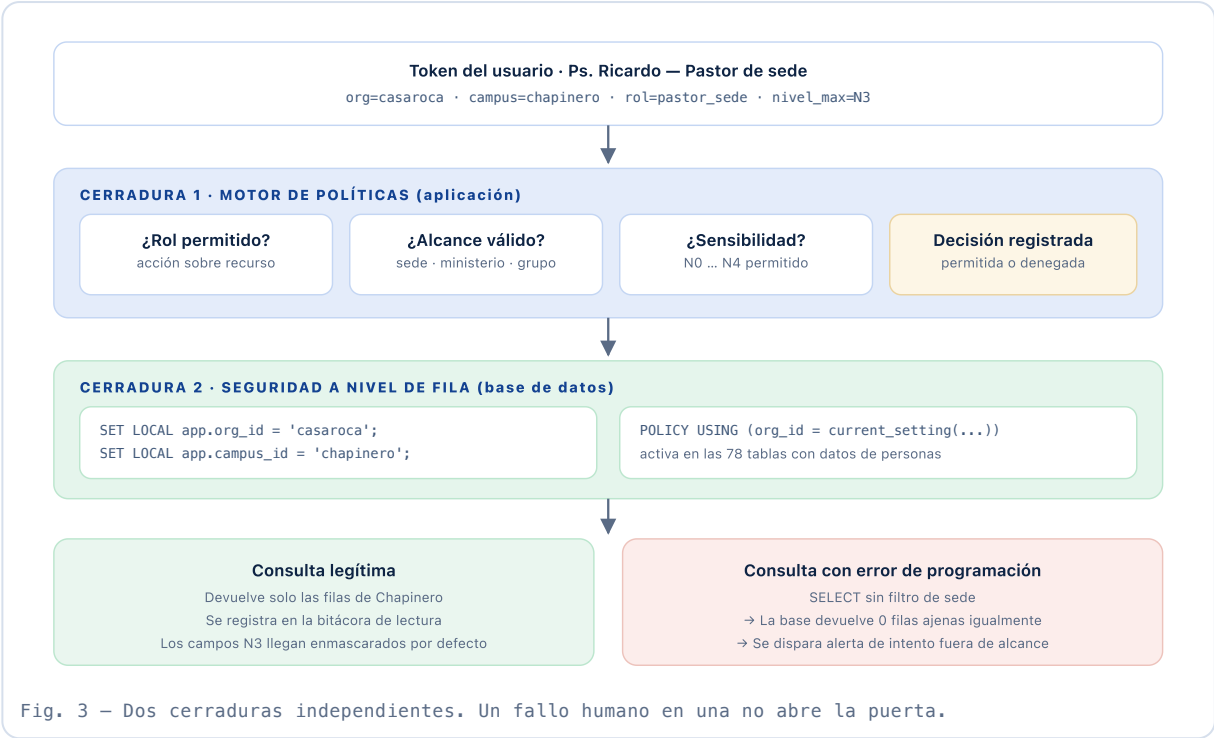
Toda tabla lleva `org_id` y `campus_id`. Antes de cada consulta, la transacción declara quién pregunta; PostgreSQL filtra por sí mismo. **Aunque el programador olvide el filtro, la base no devuelve filas ajenas.**

Por qué no una base por sede

36 bases significan 36 migraciones, 36 respaldos y consultas consolidadas imposibles. La dirección general necesita ver las 36 sedes en un tablero: eso exige base compartida.

Beneficio estratégico no menor

Al modelar `org_id` desde el día 1, la misma plataforma puede alojar **otras iglesias** sin reescribir nada. Lo que hoy es un ahorro, mañana puede ser un ingreso.

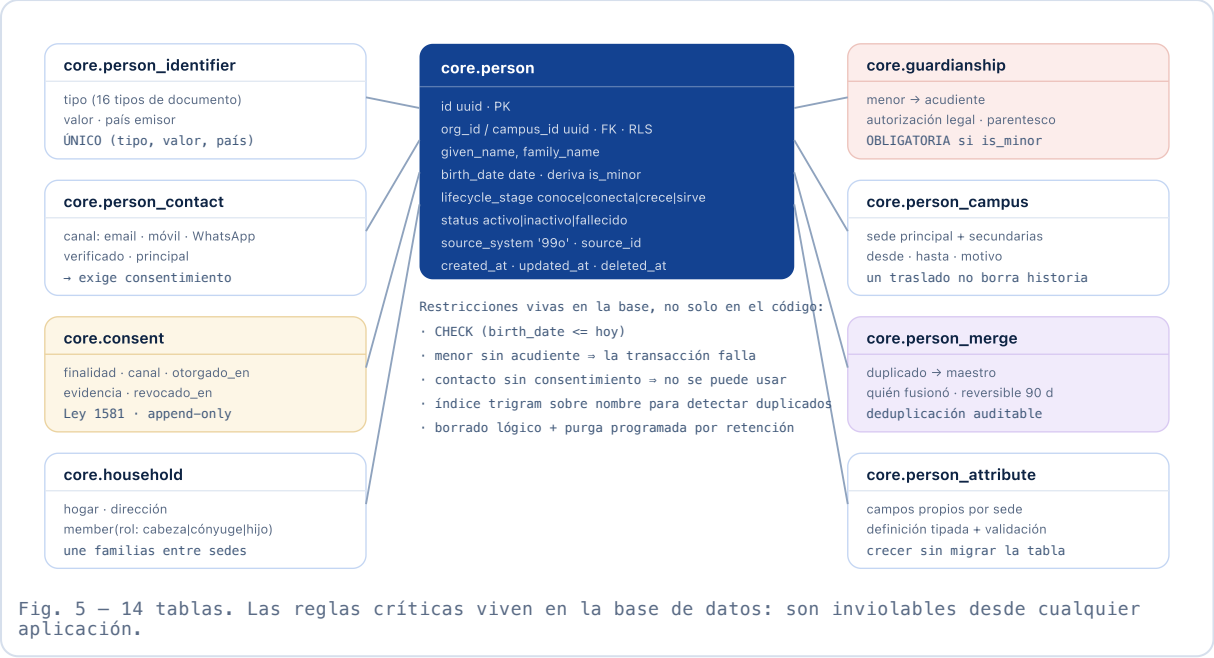


Los 11 dominios de la base de datos



Fig. 4 – Todo gira alrededor de la persona. Los dominios en rojo contienen datos sensibles o de menores y tienen reglas reforzadas.

El corazón: registro maestro de persona



La diferencia con hoy

En Fase 0 la persona vive en `localStorage` como un objeto suelto y se duplica en cada archivo de datos. Aquí hay **una sola fila**, con identidad, historia, consentimiento y linaje.

Deduplicación activa

Al crear una persona, el sistema busca coincidencias por documento, por teléfono y por similitud de nombre. Si hay sospecha, no bloquea: **crea y marca para revisión**. Fusionar es reversible 90 días.

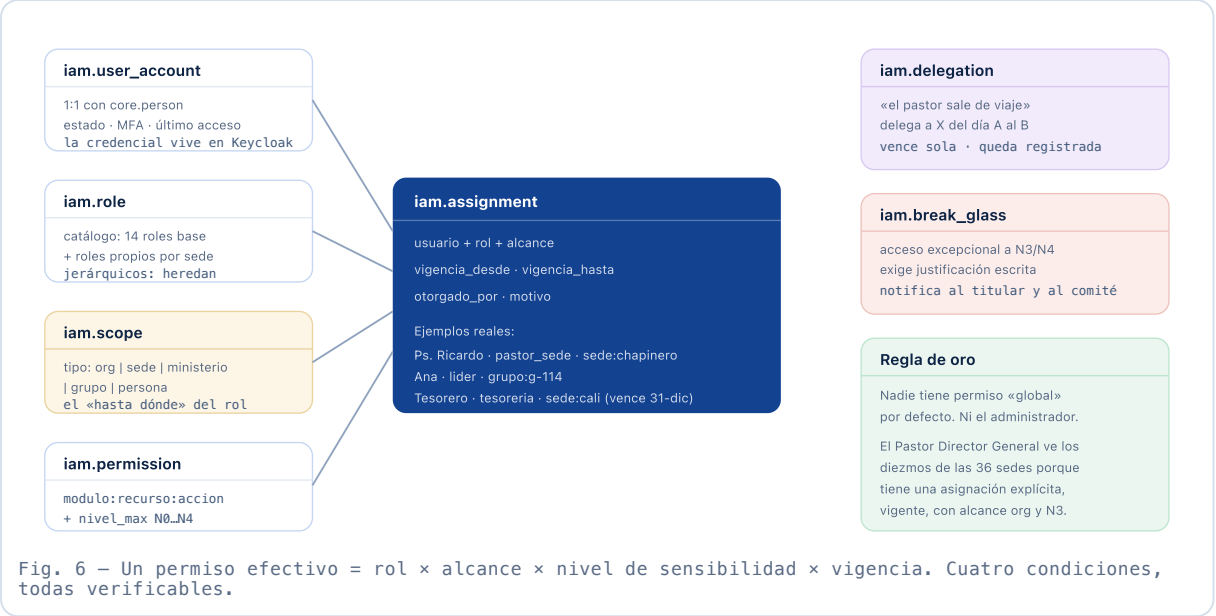
Campos propios sin migrar

Cada sede puede añadir campos («talla de camiseta», «profesión») sin que un programador toque la tabla. Van tipados y validados, no en un texto libre.

Linaje del histórico

`source_system` + `source_id` en toda fila migrada permite responder «esta persona vino de 99-o, registro 48211» y reconciliar contra el origen cuantas veces haga falta.

Usuarios, roles, alcances y permisos



Los 14 roles base

Pastor Director General	org · N3
Pastor Congregacional	sede · N3
Director de Ministerio	ministerio · N2
Coordinador	ministerio · N2
Líder de grupo	grupo · N2
Consejero	caso propio · N3
Maestro RocaKids	salón · N4 acotado
Tesorería	sede · N3 solo agregado
Contabilidad	org · N3 solo agregado
Talento Humano	sede · N3
Secretaría	sede · N2
Miembro	solo su ficha · N2
Acudiente	sus menores · N4 propio
Integración técnica	alcance del contrato · N1

Evolución desde el prototipo

La Fase 0 resuelve la identidad seleccionando un rol de una lista, con credenciales fijas en el código — apropiado para un prototipo, no para producción. La Fase 1 lo sustituye por identidad federada con MFA y permisos verificados en el servidor.

Clasificación del dato: qué se protege y cómo

No todo dato merece el mismo esfuerzo. Sobre-proteger todo hace el sistema inusable; proteger poco lo hace ilegal. Cada campo de las 126 tablas está etiquetado en uno de estos cinco niveles, y **la etiqueta activa controles automáticamente**.

NIVEL	QUÉ CONTIENE	CONTROLES OBLIGATORIOS	QUIÉN ACCEDE	RETENCIÓN	MARCO LEGAL
● NO Público	Contenido de portales, horarios, catálogo de ministerios	TLS. Sin más.	Cualquiera	Indefinida	—
● N1 Interno	Estructura de sedes, ministerios, catálogos, cursos	Autenticado + cifrado en reposo	Todo usuario del sistema	Indefinida	—
● N2 Personal	Nombre, contacto, dirección, asistencia, grupos, formación	+ Autorización por alcance · bitácora de escritura · consentimiento por canal	Rol con alcance sobre la persona	5 años tras inactividad	Ley 1581 · GDPR
● N3 Sensible	Diezmos y aportes, notas pastorales, casos de consejería, salud (AMEC)	+ Cifrado por columna con llave gestionada · bitácora de lectura · enmascarado por defecto · acceso excepcional con justificación	Solo asignación explícita N3, vigente	10 años (contable) / 3 años (pastoral)	Ley 1581 art. 5 · exige autorización expresa
● N4 Menores	Todo dato de persona menor de 18: RocaKids, acudientes, código de entrega, fotos	+ Acudiente obligatorio · doble verificación en entrega · fotos con autorización firmada · prohibida exportación masiva · alerta al comité ante acceso anómalo	Maestro de su salón, coordinador, acudiente	Hasta 2 años tras cumplir 18, luego reclasifica	Ley 1581 art. 7 · interés superior del niño

Cómo se aplica sin depender de nadie

La etiqueta va en el catálogo del sistema. La capa de datos **enmascara N3 por defecto**: para ver el valor real hay que pedirlo explícitamente, y ese pedido queda registrado con nombre, fecha y motivo.

Enmascarado, no ocultado

Tesorería ve \$ ■■■.■■■ y el total agregado de la sede. El Pastor Director General ve el valor por persona. Los dos usan la misma pantalla: cambia el permiso, no el código.

La pregunta que hoy no tiene respuesta

«¿Quién vio el diezmo de esta familia en marzo?» En Fase 0 es imposible responder. Con bitácora de lectura sobre N3, se responde en una consulta y con evidencia a prueba de manipulación.

Ciberseguridad: las 10 capas



Ciclo de vida de una petición

Ejemplo real: **el líder Ana registra una nota de seguimiento sobre una persona nueva de su grupo.** Estos son los 13 pasos que ocurren, en orden, sin que ninguno se pueda saltar.



Cómo se ancla un módulo nuevo

Requisito explícito: **poder añadir cualquier cosa en el futuro sin problema**. Se resuelve con un contrato de módulo. Un módulo declara qué es, y la plataforma lo conecta sola — sin modificar el núcleo.

```
modulos/años-dorados/module.manifest.ts

export default defineModule({
  key: 'años-dorados', version: '1.0.0',
  schema: 'mod_años_dorados',
  dependsOn: ['core.person', 'core.campus'],
  dataClass: 'N2',
  permissions: [
    'años_dorados:visita:crear',
    'años_dorados:reporte:ver' ],
  events: {
    publishes: ['visita.registrada'],
    consumes: ['persona.creada'] },
  routes: '/api/v1/años-dorados', ui: {...} })
```

- AL ARRANCAR, LA PLATAFORMA VALIDA Y CONECTA SOLA**
- ✓ ¿Las dependencias existen y su versión es compatible?
 - ✓ ¿Algún permiso choca con otro módulo ya registrado?
 - ✓ ¿El esquema le pertenece solo a él? (nadie escribe tablas ajenas)
 - ✓ ¿Los eventos que consume los publica alguien?
- Si algo falla, **el sistema no arranca**. Se detecta en despliegue, no en producción.

Fig. 9 – El manifiesto es el contrato. Sin él, el módulo no existe para la plataforma.

Añadir un módulo: 7 pasos, cero cambios en el núcleo

1. Crear la carpeta del módulo y su **manifest**.
2. Escribir sus migraciones SQL en su **propio esquema**.
3. Declarar permisos y nivel de sensibilidad del dato.
4. Implementar el servicio de dominio y sus rutas.
5. Declarar eventos que publica y que escucha.
6. Registrar la entrada de interfaz que expone.
7. Desplegar. La plataforma lo valida, lo monta y lo publica en el catálogo de módulos.

Qué hereda gratis un módulo nuevo

Autenticación, resolución de sede, motor de políticas, aislamiento por RLS, bitácora de auditoría, idempotencia, límites de tasa, validación, documentación OpenAPI, trazas y métricas. **No lo implementa: lo recibe.**

Activación por sede

Un módulo registrado no está encendido en todas partes. El Pastor Director General lo habilita por sede desde Configuración — igual que hoy en Fase 0, pero con permisos reales detrás.

La regla que evita el desorden

Ningún módulo escribe en el esquema de otro. Si necesita un dato ajeno, lo pide por el servicio del dueño o reacciona a su evento. Es lo que permite que en el año 4 se sigan añadiendo módulos sin miedo.

Apertura a APIs

CONTRATO

OpenAPI 3.1 generado del código

La documentación no se escribe aparte: se genera de los esquemas de validación, así que **nunca queda desactualizada**. Portal público de documentación con ejemplos y consola de prueba.

VERSIONES

/api/v1 · compatible hacia atrás

Se pueden añadir campos, nunca quitarlos ni cambiarles el significado. Un cambio incompatible abre /v2 y /v1 vive 12 meses más con avisos de obsolescencia.

CREDENCIALES

Una identidad por consumidor

Cada integración (Siigo, PayU, Moodle, un futuro proveedor) tiene su propia credencial, con permisos acotados, cuota propia y **revocable en un clic sin afectar a nadie más**.

SEGURIDAD

OAuth 2.1 · credenciales de cliente

Nada de llaves eternas pegadas en un archivo. Token de vida corta, alcances mínimos, lista de IP permitidas opcional y registro completo de cada llamada.

ESCRITURAS

Idempotencia obligatoria

Toda escritura acepta una clave de idempotencia. Si la red falla y el cliente reintenta, **no se duplica el registro**. Es la causa número uno de datos sucios en sistemas de iglesia.

SALIDA

Webhooks firmados

Los terceros se suscriben a eventos (persona.creada, aporte.registrado). Entrega con firma, reintentos con espera creciente y cola de fallidos revisable.

INTEGRACIÓN	DIRECCIÓN	QUÉ INTERCAMBIA	NOTA DE DISEÑO
Siigo (contable)	Salida	Resumen de aportes por fondo y sede, para asiento contable	Nunca sale el aporte por persona: solo agregados. Reduce el riesgo por diseño.
PayU (pagos)	Ambas	Cobro de cursos y eventos, confirmación por webhook, conciliación	Los datos de tarjeta jamás tocan nuestros servidores: se usa la página alojada del proveedor.
Moodle (Instituto)	Ambas	SSO de alumno, inscripciones, notas y certificados de IBLI/FACTER	Un solo usuario para todo el ecosistema; se resuelve con Keycloak sin trabajo extra.
Correo y SMS	Salida	Notificaciones transaccionales y campañas	El envío pasa por el punto de control de consentimiento: sin autorización vigente, no sale.
Tableros / BI	Entrada	Consultas analíticas contra la réplica de lectura	Nunca contra la base principal. Un reporte pesado no puede afectar el domingo.
Agentes de IA	Ambas	Consultas asistidas, redacción, resúmenes pastorales	Usan la misma API con las mismas credenciales y límites . Sin atajos ni acceso directo a la base.

Traer el histórico de 99-o sin perder nada



Fig. 10 – Nueve fases. La reversión está disponible hasta 90 días después del corte.

Operación: ambientes, entrega y continuidad



Objetivos de servicio comprometidos

Disponibilidad	99,9 %	≈ 43 min/mes
Disponibilidad domingo 7–14 h	99,95 %	ventana crítica
Respuesta API (p95)	< 300 ms	lecturas
Respuesta API (p99)	< 800 ms	escrituras
RPO · dato máximo perdible	5 min	PITR continuo
RTO · tiempo de recuperación	< 1 h	probado por simulacro

Estos números no son aspiración: se miden en el tablero y se reportan mensualmente al CTO. Si se incumplen, hay causa raíz documentada.

Continuidad · regla 3-2-1

- **3 copias** del dato: primaria, réplica en pie y respaldo.
- **2 medios** distintos: base gestionada y almacenamiento de objetos.
- **1 fuera**: copia en una **cuenta separada**, inmutable 90 días. Un atacante con credenciales de administrador no puede borrarla.
- **Simulacro trimestral**: se restaura a un ambiente limpio y se cronometra. Se entrega el acta al CTO.

Los 8 riesgos reales y su mitigación

#	RIESGO	PROB.	IMPACTO	MITIGACIÓN DE DISEÑO	SEÑAL DE ALERTA TEMPRANA
R1	Fuga de datos entre sedes por error de programación	● Media	● Crítico	Doble cerradura (políticas + RLS). Pruebas automáticas que intentan cruzar sedes en cada despliegue.	Alerta por consulta fuera de alcance
R2	Exposición de diezmos o notas pastorales	● Baja	● Crítico	Cifrado por columna, enmascarado por defecto, bitácora de lectura, acceso excepcional con justificación.	Pico de lecturas N3 por un usuario
R3	Dato de menores mal tratado (legal + reputacional)	● Baja	● Crítico	Acudiente obligatorio en la base, exportación masiva bloqueada, entrega con doble verificación, revisión legal previa.	Intento de exportar N4
R4	Migración con pérdida o duplicados	● Media	● Alto	Proceso repetible, reconciliación obligatoria, doble operación 2 semanas, 99-o en solo lectura 90 días.	Descuadre en el informe de reconciliación
R5	Caída durante el servicio dominical	● Baja	● Alto	Dos zonas de disponibilidad, escalado anticipado los domingos, modo sin conexión en la tablet de RocaKids.	Latencia creciente el sábado
R6	Dependencia de una sola persona que entiende el sistema	● Alta	● Alto	Todo como código y documentado, manual de operación, dos personas de la organización formadas, código en repositorio propio.	Un solo nombre en el historial de cambios
R7	Costo de nube que se dispara	● Media	● Medio	Presupuesto con alerta al 80 %, tope de escalado, revisión mensual. Detalle en el Documento 2.	Alerta de presupuesto
R8	Código generado por IA de baja calidad	● Alta	● Medio	Revisión humana obligatoria, cobertura de pruebas mínima exigida, análisis estático bloqueante, arquitectura que restringe lo que un módulo puede hacer.	Cobertura que baja del umbral

Nota sobre R6 · concentración de conocimiento

Es el riesgo de mayor probabilidad y de mayor impacto a largo plazo. La mitigación es organizativa además de técnica: **el repositorio, la cuenta de nube y las llaves quedan a nombre de Casa Sobre la Roca desde el día 1**, y dos personas de la organización se forman para operar el sistema de forma autónoma. El detalle operativo está en el Documento 3.



AUDITORIA

SEGUNDA PARTE DEL DOCUMENTO 1

Auditoría independiente del diseño y compuertas de ejecución

Esta sección aplica al diseño anterior una revisión estructurada contra marcos externos de referencia, registra los hallazgos abiertos con su dueño y su plazo, y define las compuertas que permiten verificar mes a mes que lo diseñado es lo que efectivamente se construye.

Cómo se revisó y contra qué

MARCO 01

OWASP ASVS 4.0 · Nivel 2

Estándar de verificación de seguridad en aplicaciones. Nivel 2 es el exigido a aplicaciones que manejan datos personales sensibles. Se revisaron los 14 capítulos aplicables.

MARCO 02

ISO/IEC 27001 · Anexo A

Controles organizativos y técnicos. No se busca certificación: se usa como lista de control para no dejar huecos de gobierno.

MARCO 03

Ley 1581/2012 + Decreto 1377

Régimen colombiano de protección de datos: autorización, finalidad, datos sensibles (art. 5), menores (art. 7), derechos del titular y registro ante la SIC.

MARCO 04

CIS Benchmarks + buenas prácticas de nube

Configuración segura de red, cifrado, gestión de llaves, respaldos y registro de actividad en la cuenta de nube.

Escala de conformidad usada

● Conforme	El diseño resuelve el control y define la evidencia que lo probará.
● Parcial	El diseño lo aborda pero deja una decisión abierta o depende de un tercero.
● No conforme	El diseño no lo cubre. Se registra como hallazgo con dueño y plazo.
● No aplica	Fuera del alcance de esta fase, con justificación escrita.

Alcance y límites de esta revisión

Esta es una **auditoría de diseño**, no de implementación. Certifica que *lo planeado* cubre los controles; **no puede certificar que lo construido los cumpla**. Para eso existen las compuertas de ejecución de la lámina 26 y la prueba de intrusión por un tercero antes de salir a producción. Presentarla como garantía de seguridad del sistema final sería incorrecto.

Matriz de conformidad · los 14 pilares

#	PILAR	ESTADO	OBSERVACIÓN DEL AUDITOR	EVIDENCIA EXIGIDA PARA CERRARLO
01	Modelo de datos	● Conforme	3FN, restricciones en la base, linaje de origen y deduplicación auditable. Adecuado.	Esquema SQL revisado + diagrama entidad-relación aprobado por el CTO
02	Multi-tenancy	● Conforme	Doble cerradura. Supera la práctica habitual, que suele confiar solo en el filtro de la aplicación.	Suite de pruebas de cruce entre sedes, ejecutándose en cada despliegue
03	Identidad	● Conforme	OIDC estándar y autoalojado. Elimina el costo por usuario y la dependencia del proveedor.	Keycloak endurecido según su guía + MFA activo en roles N3/N4
04	Autorización	● Parcial	H-01: el modelo es correcto, pero faltan definidas las reglas exactas de los 14 roles . Corresponde definirla a la organización.	Matriz rol x recurso x acción x nivel, firmada por el Ps. Director General
05	Cifrado	● Conforme	Tres niveles con llaves gestionadas y rotación. Correcto para N3/N4.	Inventario de llaves + prueba de rotación sin caída
06	Auditoría	● Conforme	Bitácora de lectura sobre datos sensibles: cubre el control de trazabilidad que faltaba en la Fase 0.	Demostración: reconstruir quién accedió a un diezmo en una fecha dada
07	Cumplimiento	● Parcial	H-02: el diseño técnico cumple, pero faltan los instrumentos jurídicos: política de tratamiento, autorizaciones, registro ante la SIC y el encargo de datos.	Documentos legales aprobados + registro SIC radicado
08	APIs	● Conforme	Contrato generado del código, versionado, idempotencia y credenciales por consumidor.	Portal OpenAPI publicado + prueba de reintento sin duplicado
09	Modularidad	● Conforme	El manifiesto con validación al arrancar es el mecanismo correcto y responde al requisito de crecimiento.	Un módulo de prueba montado de extremo a extremo sin tocar el núcleo
10	Eventos	● Conforme	Bandeja de salida transaccional. Garantía de que no se pierden eventos.	Prueba de corte de energía simulado sin evento huérfano
11	Operación	● Conforme	Todo como código, tres ambientes, azul/verde. Reproducible.	Recrear el ambiente completo desde cero, cronometrado
12	Observabilidad	● Parcial	H-03: están definidos los objetivos, falta nombrar quién recibe la alerta a las 3 a.m. y con qué tiempo de respuesta.	Rol de guardia asignado y acordado con la organización (Documento 3)
13	Continuidad	● Conforme	3-2-1 con copia inmutable en cuenta separada y simulacro trimestral. Adecuado.	Acta del primer simulacro con tiempo real de restauración
14	Migración	● Parcial	H-04: el proceso es sólido, pero aún no se ha confirmado cómo exporta 99-o: si no hay salida completa, cambia el esfuerzo real.	Exportación de prueba de 99-o obtenida y perfilada

10

pilares **conformes**

4

pilares **parciales** · 4 hallazgos abiertos

0

pilares **no conformes**

71 %

conformidad plena de diseño antes de construir

Los 4 hallazgos abiertos, con dueño y plazo

Ninguno impide empezar. Los cuatro bloquean fases posteriores si no se cierran a tiempo. Se registran aquí, con dueño y plazo, para que la mesa pueda hacerles seguimiento.

H-01 · SEVERIDAD ALTA

Falta la matriz de permisos firmada

Qué falta: la definición exacta de qué puede hacer cada uno de los 14 roles sobre cada recurso. El diseño soporta cualquier configuración; alguien tiene que decidir cuál.

Riesgo si no se cierra: se construye sobre supuestos y el resultado puede no reflejar el modelo de gobierno real de la organización. Rehacerlo después tiene un costo elevado.

Dueño: Dirección General, con Dirección Financiera · **Plazo:** antes de iniciar la Fase 2 de construcción.

H-02 · SEVERIDAD ALTA

Faltan los instrumentos jurídicos de datos

Qué falta: política de tratamiento de datos, textos de autorización por canal, aviso de privacidad, autorización específica para menores, registro de bases de datos ante la SIC y contrato de encargo del tratamiento con todo tercero que acceda a datos personales.

Riesgo si no se cierra: el sistema puede ser técnicamente impecable y aun así **operar de forma ilegal**. Con datos de menores, la exposición es seria.

Dueño: Área Legal, con apoyo del equipo técnico · **Plazo:** antes de cargar datos reales de producción.

H-03 · SEVERIDAD MEDIA

Falta definir la guardia operativa

Qué falta: quién responde a una alerta fuera de horario, en cuánto tiempo, y qué pasa si no responde. Hoy no hay nadie asignado.

Riesgo si no se cierra: se cumple el 99,9 % en el papel y se incumple en la práctica el primer domingo con incidente.

Dueño: Dirección de Tecnología · **Plazo:** antes de la salida a producción. Modelo propuesto en el Documento 3.

H-04 · SEVERIDAD MEDIA

No se ha verificado la exportación de 99-o

Qué falta: confirmar que 99-o entrega una exportación completa —incluida la bitácora histórica de actividades, que es la pieza más valiosa— y en qué formato.

Riesgo si no se cierra: si solo hay exportación parcial, la migración pasa de proceso automático a extracción asistida, y **el esfuerzo y el costo cambian**.

Dueño: Administración de 99-o · **Plazo:** primera semana. Es la tarea de menor costo y la que más incertidumbre elimina.

Observación adicional del auditor — no es hallazgo, es advertencia

El diseño depende de que la construcción la ejecuten asistentes de IA bajo revisión humana. **La calidad del resultado será tan buena como la disciplina de esa revisión.** La arquitectura ayuda —restringe lo que un módulo puede hacer mal— pero no sustituye a un humano que lea el código. Si la revisión se relaja para ir más rápido, el riesgo R8 se materializa y ninguna de las 10 capas de seguridad lo impide.

Las 7 compuertas: cómo se comprueba que se está ejecutando

El seguimiento debe confirmar que el plan **se ejecuta**, no solo que existe. Cada fase termina en una compuerta con evidencia objetiva. **Sin evidencia no se pasa**, aunque el calendario apremie. La evidencia se entrega al CTO.

PUERTA	CIERRA LA FASE	EVIDENCIA OBJETIVA EXIGIDA	VERIFICA	SI NO PASA
G0	Diseño aprobado	Este documento revisado y firmado · matriz de permisos (H-01) entregada · exportación de 99-o verificada (H-04)	CTO + CFO	No se escribe una línea de código.
G1	Fundación en pie	Infraestructura recreada desde cero en < 1 h · base sin ruta pública comprobada · RLS activo verificado con prueba de cruce entre sedes · bitácora funcionando	CTO	No se cargan datos reales.
G2	Identidad y permisos	MFA operando en roles N3/N4 · los 14 roles configurados según la matriz firmada · demostración en vivo: un pastor no ve otra sede	CTO + Ps. Director	No se abren módulos de negocio.
G3	Núcleo funcional	Persona, grupos, asistencia y línea de tiempo operando · cobertura de pruebas ≥ 70 % en el núcleo · OpenAPI publicado · prueba de idempotencia superada	CTO + Desarrollo	No se inicia la migración.
G4	Migración validada	Informe de reconciliación al 100 % · 30 fichas auditadas a mano · todo menor con acudiente · sumas de aportes idénticas al peso	CFO + Ps. Director	No hay corte. Se repite el ciclo.
G5	Seguridad verificada	Informe de prueba de intrusión de un tercero , con hallazgos críticos y altos remediados y reverificados · instrumentos jurídicos listos (H-02) · guardia asignada (H-03)	CTO + Legal	No se sale a producción. Sin excepción.
G6	Operación estable	30 días con objetivos cumplidos · primer simulacro de restauración con acta · dos personas de la organización formadas y operando · manual entregado	CTO + CFO	No se cierra el proyecto ni se da de baja 99-o.

Mecanismo de verificación

La verificación de cada compuerta corresponde a la organización: el equipo de construcción presenta la evidencia y la Dirección de Tecnología determina si la fase queda cerrada. La evidencia es objetiva y queda archivada como respaldo del proyecto.

Cadencia de reporte

Informe quincenal de una página: qué compuerta está abierta, qué evidencia se lleva acumulada, qué hallazgos se cerraron y cuáles siguen abiertos con su plazo. El calendario detallado va en el Documento 3.

Conclusión de la revisión

Requisito 01 · Arquitectura de datos

Resuelta en diseño. Modelo relacional en 11 dominios, ~126 tablas, restricciones vivas en el motor, linaje del histórico y deduplicación auditable. El volumen de 25.000 personas y 36 sedes está holgadamente dentro de la capacidad diseñada.

Requisito 02 · Apertura a APIs

Resuelta en diseño. Contrato OpenAPI generado del código, versionado con compatibilidad garantizada, credenciales por consumidor, idempotencia y webhooks firmados. Seis integraciones ya mapeadas, incluidos los agentes de IA bajo el mismo contrato.

Requisito 03 · Ciberseguridad

Resuelta en diseño, pendiente de verificación externa. Diez capas independientes, clasificación del dato en cinco niveles, bitácora de lectura sobre datos sensibles. La confirmación llega con la prueba de intrusión en la compuerta G5.

Requisito 04 · Fundación de datos

Resuelto en diseño. Se conserva PostgreSQL como motor y se descarta la plataforma como fundación de producción. Cada componente propietario fue reemplazado por uno con alternativa estándar.

Lo que esta auditoría NO certifica

No certifica el sistema construido —todavía no existe—. No sustituye la prueba de intrusión ni el concepto legal. No garantiza plazos ni costos: eso lo evalúan los Documentos 2 y 3.

Condición para el veredicto

El veredicto es **favorable con condiciones**: los cuatro hallazgos deben cerrarse en su plazo, y las siete compuertas deben verificarse con evidencia. Si eso no ocurre, esta auditoría deja de aplicar.

Dictamen

El diseño presentado es **apto para pasar a construcción**. Cubre 10 de 14 pilares en conformidad plena y 4 en conformidad parcial, sin ningún incumplimiento. Los hallazgos abiertos son de gobierno y de terceros —permisos, instrumentos legales, guardia y exportación de origen—, no de arquitectura. **Se recomienda abrir la compuerta G0 una vez entregada la matriz de permisos y verificada la exportación de 99-o.**